Data privacy and security note

Udyam Digital · MSME onboarding for NorthStar · Airtel SYNC, Enterprise Track A

Designed against the DPDP Act, 2023

Principle: collect only what each step needs, only after consent, keep it only as long as needed, and never show or log a full identifier. Every point below describes how the working prototype behaves; items marked **Production** are what we would add before launch.

1 · Consent before any KYC data

- A notice is shown before any document upload: purposes, data collected, data *not* collected, retention, grievance contact.
- Consent is per purpose. *KYC verification* and *service activation* are required. *Marketing* is optional and off by default.
- Each consent gets an ID and a timestamp (audit trail). Withdrawing it from the KYC screen erases that application's KYC data.

2 · Purpose limitation

- KYC data is used only to verify the business and activate the services ordered.
- The GenAI advisor needs no personal data. It is instructed never to ask for Aadhaar, PAN, bank details or documents in chat.
- Marketing messages only with the separate, optional consent.

3 · Data minimisation: what we collect, and why

Step	Collected	Why it is needed	Never collected
Advisor	Business type, city, staff, sites, needs (no names or IDs)	Pick an eligible bundle and price	Aadhaar number, bank or card details, personal photos, date of birth
KYC	GSTIN, Udyam no., business name and address, signatory name and ID validity, bill date	Verify the business is real, active and at that address	
Order	Mobile number	Order updates and e-sign link	
Callback (optional)	Mobile number, only if the owner taps "Talk to a person"	So a local partner can call back	

4 · Storage and retention

- **Document images are never stored.** They are processed in memory, the fields are extracted, and the image is discarded.
- Only the extracted fields and the verdict (approve / review / reject with reasons) are kept, linked to the consent ID.
- Retention: for the contract term, plus any period telecom KYC rules require. The prototype states contract term + 8 years; **Production:** confirm the exact period with legal against DoT rules. Then delete automatically.

5 · Masking everywhere

- Identifiers are masked in the UI, in API responses and in the order record: GSTIN `32TT********1ZW`, Udyam `UDYAM-KL-*******801`, phone `98******10`.
- Logs record only the KYC application ID, document type and how it was read, never field values.
- Journey state lives in the browser's session storage and is gone when the tab closes.
- The partner desk is behind an access key and shows leads as a business profile (segment, size, city tier) with a masked callback number, never names or IDs.

6 · Use of AI (Gemini)

- Gemini receives only the uploaded document image (to read it) and the chat text. No stored customer records are sent.
- AI never makes the KYC decision alone. Deterministic rules decide: GSTIN check digit, registry status, cross-document matching. AI output that fails the check digit is rejected.
- **Production:** move from the free API tier to an enterprise tier with no training on customer data and India data residency.

7 · Security controls

- Uploads limited to PNG, JPEG, WEBP or PDF up to 8 MB. Typed validation of API inputs (e.g. Indian mobile number format).
- API keys kept in an environment file, never in code or the repository.
- **Production:** TLS everywhere, encrypted database and backups, role-based access and audit logs for the partner/back-office view, rate limiting, secrets in a vault, and annual security testing.

8 · Owner rights

- Access: the order tracker shows the business details, services and status we hold.
- Correction: re-upload any document. Erasure: withdraw consent before activation; after activation, on request once legal retention ends.
- A named grievance contact is shown on the consent screen.

9 · Breach response

- Because images aren't stored and identifiers are masked, a breach exposes far less.
- Incident runbook: contain, assess, then notify the Data Protection Board and affected owners as the DPDP Rules require. Then review and fix.

All businesses, people and identifiers in the prototype are synthetic (hackathon dataset). The case's fictional operator, Accel Telecom, is branded NorthStar in the prototype.